



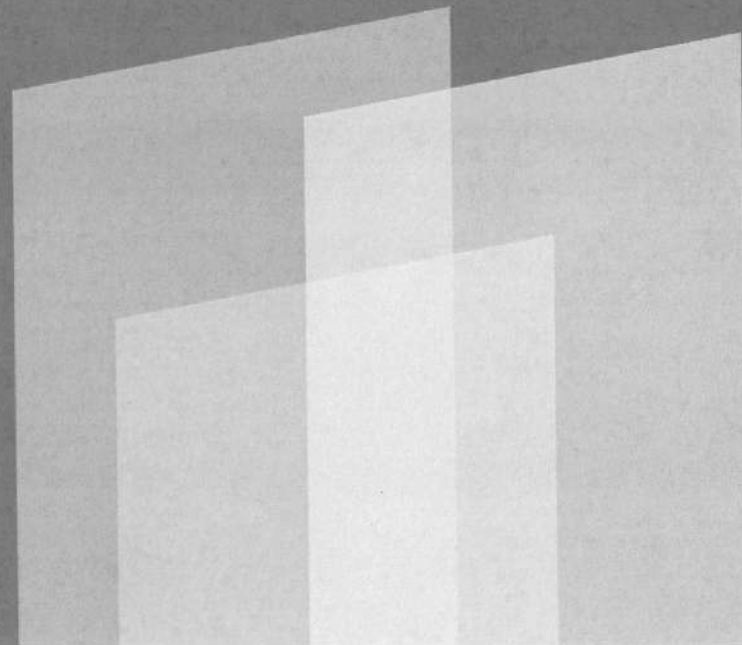
APAC Patch Management Process

Deviation of SSMR 45 days requirement

TSG Infra



SMBC



Background

1. The patch management in HO Security Standard require security patches for all IT products to be completed within 45 days from the vendor released date.

Security Standards				Responsible Department		Planni ng Stage	Action Rank			Items for Infrastructure				
(Note)If the evaluation guide within the same criteria spans multiple lines, the description of the same criteria from the second line onward should be grayed out.														
Item			Standards	System	Services/ Operations	Standards	A	B	C		Risks	Conditions of application	S/E	Evaluation guidelines (Note) S1, S2, S3, S4: Evaluation criteria E1, E2, E3: Expanded conditional evaluation criteria
1. Information Security	5. Countermeasures for Computer Virus and Other Malicious Programs	(5) Countermeasures for Computer Viruses and Other Malicious Programs (Security Patches)	Apply proper security patches to OS, middleware, applications, etc., as per the corporate policy to prevent damages from malicious programs (computer virus, etc.), unauthorized access, etc.	○		○	○	○	○	Security attack risk	Mandatory	S	(S1) Application of security patches Apply the security patches for OSs, middleware, applications, etc., within 45 days of announcement by respective vendor, etc. Regarding various OSs, middleware, application products, etc., if it takes a long time to comprehensively apply the security patches, the usage of virtual patch tools is allowed.	

2. The Patch Management Operation Manual was initiated in Mar 2024 for SMBC SNG which provided general guidance for patch processes.

Problem Statements

- 1. Most branches cannot meet the 45 days system patch requirement.**
 - a. A Risk Acceptance (RA) had the 6th renewal in Oct 2025 for the patch deviations
 - b. The RA raised by TSG-DCS, which only covered Microsoft & RHEL OS and databases.

- 2. There are grey areas for patch coverage for network devices, any software that's not included in the RA are part of the regular review and patch activity.**
 - a. Not all network devices and appliances are recommended to apply the latest patch, no formal guidance established across APAC.
 - b. Majority of desktop and server software are not part of the regular review and patch activity; system PICs only rely vulnerability scan to detect if any action required for patch.

- 3. Lack of diligent in raising RA for patch unable to meet 45 days requirement due to time consuming in RA process.**
 - a. System PIC opt to catch up the patch rather than raising an RA (most case is faster).
 - b. This led to completed patch remain in overdue status and lack of management awareness.

- 4. Lack of visibility of patch management**
 - a. A patch monitoring for Microsoft and RHEL OS is introduced in JIRA.
 - b. This helps to detect overdue patches; however, accuracy of compliance rate is not 100% (completion date based on next scan result)

Objective

1. To establish a sustainable APAC Patch Management process
2. Apply appropriate prioritization for IT asset based on system criticality, exposure and device category.
3. Identify team / resource for governance and monitor
4. To establish a process for easing risk acceptance specific for patch management deviation.
5. Improved patch reporting for better visibility.

Proposals

1. A Risk-based approach to redefine the priority and targets based on system and patch criticality. Introduce quarterly patch review exercise for patch unable to meet SSMR requirement.
2. Enhance exception handling by introduce "Patch Extension Request" as pre-approved Risk Acceptance, subject to criteria is met.
3. Centralized Patch Control function – a working group from TSG to review and track the patch deployment to enhance patch visibility for management awareness

1. Risk-based Targets

In view of a large technology and cyber landscape subjected to be patched, a risk-based approach¹ based on system criticality and product category is considered. Prioritization applies to higher ranked systems and higher exposure to external IT asset. Introduce quarterly review processes for IT asset that's unable to meet the requirement.

Product / Asset type	Network segment	System rank	Target
All approved product	DMZ (External)	All ranks	45 days
Server OS Endpoint OS Endpoint software ² Database Anti-virus products	Internal	All ranks	45 days
Any non-standard products	DMZ (External) / Internal	All ranks	45 days
Network devices	Internal	All ranks	90 days ³
All other approved products	Internal	Rank A	45 days
	Internal	Rank B	90 days
	Internal	Rank C and Non-rank	180 days

Approved software refers to product listing in APAC Technology Standard

Additional controls

1. Not all IT assets are recommended to apply with latest patch release such as network devices. For such cases, it is recommended for the **system PIC to conduct quarterly reviews to ensure the IT assets are running with recommended patch release**. The target measure should be based on completion date of quarterly review.
2. For patch which involves remediation of **high urgency levels of vulnerabilities with a CVSSv3 score of 4.0 or higher and with an access vector of Network are determined, the target should shift to 30 days**, this applies to all product categories. Emergency change to be considered to accelerate the patch deployment.
3. All IT assets should carry out regular security vulnerability scans as per APAC vulnerability management. **Any security vulnerability found on the IT asset; the remediation timeline will be based on remediation target (P1, P2 or P3) as per Vulnerability Management Procedure Manual or Patch Management Procedure Manual whichever imposes a stricter lead time.**

¹ The deviations of 45 days requirement in SSMR to be supported by an APAC Risk Acceptance up to Sep 2026 while continue to work with HO for longer term guideline or perpetual risk acceptance.

² For non-Microsoft endpoint software, **system PIC to review and assess quarterly for patch identification, the target should be measured based on completion quarterly review.**

³ Network device patch to be reviewed quarterly, the identified patch to be applied based on the report and target measure will be based on completion of the review.

Deviation of SSMR Requirement

Below is the summary of changes regarding the 45 days target timeline between SSMR / Security Standards and the proposed APAC Patch Management Process.

Product	Network segment	Asset type	Target	Deviations from original target of 45 days	Estimated count for hosts / devices
All approved product	DMZ (External)	All rank	45 days	NIL	Server OS= 76 Network/Appliances = 52
Server OS Endpoint OS Endpoint software Database Anti-virus products	Internal	All rank	45 days	NIL Endpoint software quarterly review (every 90days) + To complete within 45 days Total about 90 days of deviation	Servers OS = 1,905 Endpoint OS = 2,115 Database = Est 25% of servers Endpoint software = Est 100/end point
Any non-standard products	DMZ (External) / Internal	All rank	45 days	NIL	
Network devices	Internal	All rank	90 days	Quarterly review (every 90days) + To complete within 90 days Total about 135 days of deviation target.	Appliance = 401 Network devices = 724
	Internal	Rank A	45 days	NIL	Software resided in 122 servers
All other approved products	Internal	Rank B	90 days	+45 days	Software resided in 547 servers
	Internal	Rank C and Non-rank	180 days	+135 days	Software resided in 1,236 servers

Total 5,273 IT asset based on VA scan inventory as of Jan 2026.

2. Exception Handling Enhancement

The proposed process will enhance the exception handling process which include post exception handling process.

1. Any security patch is anticipated unable to meet the stipulated target timeline, the relevant System PIC should obtain necessarily approval.
2. Patch Extension Request - to allow a one-time patch deployment extension of up to 45 days under specific conditions, subject to management approval.

Eligibility Criteria for Extension:

- a. Non-P1 Vulnerability
- b. Non-Internet Facing Asset
- c. An approved product in Technology Standard

Otherwise, a Risk Acceptance (RA) form should be submitted in accordance with the prevailing RA process along with submission of an eMemo request for Management's approval.

3. For post exception handling process, any patch implementation completed but exceeded the stipulated timeframe without Patch Extension Request or Risk acceptance, the system PIC should notify management through an email, eMemo or any official management update meetings.

The patch extension request is a form of Risk Acceptance that allow the system PIC to utilize effort to accelerate the patch deployment and reduce administration when pre-approved criteria are met.

3. Formation of Infra Operation Working Group

Below the TOR draft for APAC TSG Infra Operations Working Group which set to cover Central Patch Control Function.

1. Working Group Co-Leads		2. Working Group Members		3. Mtg Cadence		
Lay Koon T (MKL) Allan L (SNG)		Ferlene T (SNG) Jude A (SNG) Danny T (SNG) VA Ops TBC (SNG)		Monthly, 1 hour		
4. Key Purposes		5. Scope				
a. To identify key operational gaps to address b. To identify key operational inefficiencies to improve c. To identify key operational risks to manage d. To propose and oversee the implementation of solution as response e. To serve as central control function for selected operational areas		• (Depts) IT Infra under Asia Pacific Div, India Div and JRIS-ITS • (Subject) Patch and Vulnerability Management • (Subject) Standard Change Templates • (Subject) Operations KPI Metrics - later • (Subject) Operations Target Operating Model - later				
6. Meeting Agenda		7. RACI Matrix				
1) Review action items from previous meeting 2) Central Patch Control Function • Review latest Patching and VA summary report • Discuss handling of overdue patches and VAs • Discuss outstanding VA-related challenges 3) Standard Change Templates (SCT) • Review status of agreed SCT to build and publish • Review list of SCT candidates 4) Identification of new Operational Gaps / Inefficiencies / Risks 5) Any other business		Activity	WG Co-Lead	WG Members	Ops. PICs	TSG MGMT
		Schedule WG Meeting and set discussion agenda	A, R	C	C / I (opt.)	I
		Prepare / collect updates for WG review	A, R	R	C / R (opt.)	I
		Identify and document action items (including closure) from WG discussion	A, R	C	C / I (opt.)	I
		Execute WG action items	A, R	R	I / R (opt.)	I
		Report WG status updates	A, R	C	C / I (opt.)	I

Implementation Approach

Based on Vulnerability Management Procedure Manual, long term deviation of SSMR is subject to approval / clearance from HO, we propose implementation in 2 stages.

1. To seek GPDAP SAG and ITAPD management Risk Assessment approval to effect APAC Patch Management Process v2 for 1-year, with effective of additional controls, use of patch extension to ensure management awareness and attention when any operation shortfall.
2. While operating APAC Patch Management Process v2, operational feedback to be collected for enhancement along with clearance with HO for long term deviation and controls to be put together.

Next Steps

The effectiveness of quarterly endpoint and server software patch reviews is constrained by a manual, multi-source verification process that is not sustainable at scale. Dependence on manual cross-referencing across ITAM, system inventories, and vendor portals elevates the risk of gaps in coverage and inconsistent assessments.

Without improved automation and risk-based prioritization, there is a material risk that vulnerabilities may not be proactively identified and remediated, impacting overall cyber risk management and control assurance.

1. Propose to initiate a structured evaluation of a solution/platform capable of automated discovery, correlation, and risk-based prioritization across endpoints, servers, and applications.
2. This identified solution/platform should aim to:
 - a. Strengthen cyber risk controls
 - b. Improve risk transparency and decision-making
 - c. Integration with existing tools (ITAM, DSI, JIRA, etc.)
 - d. Ability to patch to key products and integrate/orchestrate with existing patch management tool.
 - e. Accurate reporting with completion timestamp, performance scorecard & dashboard monitoring.
 - f. Reduce reliance on manual, error-prone processes.

Appendix

Patch Management Process 2.0 (Draft 5)

Risk Assessment (Current Security Controls)

1. Logical network segregation between external and SMBC internal network restricts lateral movements and reduces the chances of cyber attack.
2. The network hosts are not directly accessible from the Internet, limiting attacks originating from the Internet.
3. Internet web browsing sessions are secure in isolated remote cloud browsers to reduce the chances of malware (targeting the vulnerabilities) being introduced into the SMBC environment from undesirable/malicious websites or emails.
4. Privileged access is controlled and managed through the CyberArk PAS solution to minimize the risk of compromised privileged credentials during undesirable attempts.
5. Systems are being hardened to reduce likelihood of attack surfaces to the systems in the environment.
6. The network environment is being monitored with network anomaly detection tools that enable the APAC SOC to identify unusual events or suspicious behavior if the vulnerabilities are being exploited to conduct illicit system activities.
7. Regular vulnerability assessment scanning are conducted and monitored via JIRA reporting tool which provide System PICs and System Custodian an updated posture of the security status and makes it easier to identify priority areas for security improvement.
8. System with highly exposed such as internet facing, endpoint and critical systems will be within stipulated target timeline to reduce the vulnerability exposed.

APAC Infra Rationalization - PROGRAM MONTHLY STATUS REPORT

Program Name	Program Delivery Lead	Reporting Period	Program Objectives	Program RAG
APAC Infrastructure Rationalization	Allan Lau	Mar 1, 2026 – Mar 31, 2026	1. Develop APAC infrastructure system standard under hybrid model of on-prem and cloud 2. Migrate branches infra components into regional systems for cost, scalability & manageability	GREEN

Executive Summary	General Standing up of Infra Rationalization Working Group to guide high-level solution decisions affecting Infra landscape	Key Milestones and Deliverables			
	Updated assessment approach (duplicate systems) - Updated approach to spend ~2 man-days per system to identify opportunities for standardization / reduction of systems - Batching into manageable sets of systems for more effective handling and progressive outputs Contracts Enhancement - Regional Network and Security Infra Enterprise Agreement: Commencing fresh round of diligent validation (est. 6 months) of inventory details across the region	#	Milestone / Deliverable	Completion Date	Progress
		1	Complete tech assessment	31 May 2026	20%
		2	Initiate follow-up projects	30 Jun 2026	0%
		3	Regional Infra contracts	31 Mar 2027	10%
		4	Infra Arch. Support Model	31 Mar 2027	0%

Upcoming Activities for Leadership Attention	1. Next focus area for infra rationalization review: - Process and artifacts to facilitate central rationalization assessment for cloud migration / containerization / VM on-prem / Others 2. First Batch of Duplicate Systems Assessment Outcome - ETA by end-Mar, assessment details and outcomes will be documented 3. Regional Enterprise Agreement (Network and Security Infra): - Proceeded with MA renewal for SNG, restarted work to conclude EA for the region over another 6 months
--	--

Current Month – RAG Status and Interpretation			Previous Month
Overall Program Health		Revised assessment approach and re-forecasted delivery milestones; To seek DGM approval of milestones / deliverables / target dates	
Finance		Budget management is decentralized at (forecasted) demand level	
Resource		Renewed dedication from Infra Architect resources to commit reasonable time on this program	
Schedule		Schedule is not fixed yet, conducting best-effort progressive discovery work for now	

Key Risk & Issue Summary	Details		Mitigation Plan	
	Lack of resource dedication		- Re-designed assessment approach with time commitment from Infra Architect resources - Tactical review with standardization and reduction focus	